# Autorisation de test de s��curit�� (mandat)

# Autorisation de test de sécurité (mandat)

> *Version pré-remplie, prête à signer. Les champs en **[À COMPLÉTER]** ne peuvent l'être que par les parties. Ce document n'est pas un avis juridique ; à faire valider par le responsable concerné / un juriste côté ProjetLocatif.*

---

**Entre les soussignés :**

- **Le Commanditaire / responsable du système et des données :** Société : **[À COMPLÉTER — raison sociale exacte de l'éditeur/exploitant de `app.projetlocatif.fr`]** Représentée par : **Robin ELDIN**, en qualité de **[À COMPLÉTER — ex. dirigeant / gérant]**, dûment habilité à autoriser des tests sur la plateforme et les données qu'elle traite. Ci-après « le Commanditaire ».
- **L'Intervenant :** Nom : **Nicolas BRANDEJSKY**, conseiller (compte utilisateur id **8570**). Ci-après « l'Intervenant ».

## 1. Objet

Le Commanditaire autorise l'Intervenant à réaliser un **test de sécurité** (évaluation des contrôles d'accès) sur la plateforme `app.projetlocatif.fr`, afin de vérifier l'**étanchéité des droits entre comptes** : accès à des données hors du périmètre d'un conseiller (**IDOR**), **élévation de privilèges**, et **contrôle d'autorisation objet par objet** côté serveur.

## 2. Périmètre autorisé

- Cibles : **[À COMPLÉTER — URLs / endpoints / modules]** (par défaut : endpoints `/api/*` de l'espace conseiller — prospects, properties, sales, mandats).

- Environnement : **[X] Recette/staging dédié (recommandé)** ☐ Production
  URL de l'environnement : **[À COMPLÉTER]**
- Comptes de test fournis : **[À COMPLÉTER — au moins 2 comptes A et B qui ne doivent pas se voir]**
- Types de tests autorisés : contrôle d'accès / **IDOR** / élévation de privilèges / CSRF / exposition d'information.

## 3. Exclusions (sauf accord écrit complémentaire)

- Pas de déni de service (DoS), pas de test de charge destructif.
- Pas d'extraction massive de données ; en cas d'accès non autorisé démontré, l'accès est constaté sur un **échantillon minimal** suffisant à la preuve, puis **cessé immédiatement**.
- Pas de modification/suppression de données de production appartenant à des tiers.
- Pas d'ingénierie sociale sur les salariés/clients, pas d'accès aux comptes de tiers réels.

## 4. Données personnelles (RGPD)

Si des données personnelles de tiers sont rendues visibles par une faille, l'Intervenant ne les copie pas, ne les diffuse pas, les mentionne dans le rapport uniquement de façon anonymisée / au strict nécessaire à la preuve, et les signale sans délai au Commanditaire.

## 5. Confidentialité et divulgation responsable

Les constats sont **confidentiels**, remis au seul Commanditaire via : **[À COMPLÉTER — contact technique + e-mail]**. Aucune publication sans accord écrit.

## 6. Durée

Du **[//____]** au **[//____]**, de **[__h]** à **[__h]** (fenêtre de test).

## 7. Responsabilité et bonne foi

L'Intervenant agit dans le seul cadre défini ci-dessus. Les actions menées dans ce périmètre et cette fenêtre sont réputées **autorisées** par le Commanditaire, responsable du système et des données testées.

---

Fait à ……, le ……/……/……, en deux exemplaires.

**Le Commanditaire L’Intervenant** Robin ELDIN, pour [société ProjetLocatif] Nicolas BRANDEJSKY Qualité : …… Conseiller (compte 8570) Signature : _____ Signature : _____